

Crowdfunding

Crowdfunding.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Campana de financiacion colectiva: los usuarios aportan ETH hacia una meta (goal) antes de un deadline; el owner retira los fondos y los aportantes pueden reembolsarse.
Actores	Owner (despliega, retira), Aportantes (contribute/refund). Sin protocolos externos.
Flujo de fondos	ETH entra por contribute() y queda en el contrato. Sale por withdrawAll() (owner) o refund() (aportante).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Reembolso repetible / Reentrancy en refund() Root: No se actualiza el estado (contributions) antes/despues de la transferencia; se viola Checks-Effects-Interactions.	refund() envia ETH con call() pero NUNCA pone contributions[msg.sender] a 0. El aportante puede reentrar o simplemente volver a llamar refund() en transacciones sucesivas y drenar fondos de otros. Vector: Tras el deadline, un aportante llama refund() en bucle (reentrante o repetido) hasta vaciar el contrato.	Critical	SWC-107	SC08:2026 Reentrancy
2	Owner puede retirar todo sin condiciones (rug pull) Root: Logica de exito de campana ausente; goal declarado pero no validado.	withdrawAll() permite al owner llevarse address(this).balance en cualquier momento, sin comprobar si se alcanzo goal ni si paso el deadline. La variable goal nunca se usa. Vector: El owner llama withdrawAll() y se queda con todas las aportaciones, dejando insolvente a refund().	High	SWC-105	SC02:2026 Business Logic Errors
3	Carrera de fondos entre owner y aportantes Root: Contabilidad unica sin segregar fondos por estado de campana.	withdrawAll() y refund() compiten por el mismo balance; quien ejecute primero deja sin fondos al otro. No hay separacion contable. Vector: Front-running entre owner y aportantes para vaciar el balance comun.	Medium	SWC-114	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

goal nunca se comprueba; no existe estado de exito/fracaso; refund no exige haber fallado la meta; insolvencia garantizada si owner retira primero.

6. Benchmark metrics

3 Total	1 Critical	1 High	1 Medium	0 Low	0.92 Confidence	0.90 Precision	1.00 Coverage	55 Time (s)	82 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

ElectionChain

ElectionChain.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Sistema de votacion on-chain: registra votantes, permite emitir un voto por candidato y contabiliza resultados.
Actores	Votantes (vote), cualquiera (registerVoter/reRegister). No hay administrador definido.
Flujo de fondos	No mueve ETH. Estado: registered[] y votes[].

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Registro de votantes sin control de acceso Root: Falta modificador de autorizacion (onlyAdmin) en el alta de votantes.	registerVoter(address) es publica y no valida quien la llama. Cualquiera puede registrar direcciones arbitrarias (incluidas miles propias) para votar. Vector: Ataque Sybil: el atacante registra N direcciones y vota N veces.	Critical	SWC-105	SC01:2026 Access Control
2	reRegister permite votos ilimitados Root: Funcion administrativa expuesta que revierte la unica salvaguarda anti-doble-voto.	vote() pone registered=false para evitar doble voto, pero reRegister(address) (publica, sin control) lo vuelve a poner true, anulando la proteccion. Vector: vote() -> reRegister(self) -> vote() en bucle: relleno de urnas ilimitado.	Critical	SWC-105	SC01:2026 Access Control
3	Ausencia de fases y de identidad real del votante Root: Modelo de gobernanza incompleto.	No hay inicio/cierre de votacion ni vinculacion de identidad; el conteo puede manipularse en cualquier momento. Vector: Manipulacion del resultado sin ventana temporal ni autenticacion.	Medium	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

La integridad electoral es nula: cualquiera registra y re-registra a voluntad, por lo que el resultado de votes[] no es confiable.

6. Benchmark metrics

3	2	0	1	0	0.93	0.92	1.00	45	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Nucleo de una DAO: registro de miembros y una funcion de calculo agregado. Acepta ETH.
Actores	Miembros (join), cualquiera (compute). Sin owner.
Flujo de fondos	Recibe ETH via receive() pero no existe ninguna funcion para retirarlo.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	ETH bloqueado de forma permanente Root: Falta logica de salida de fondos (withdraw).	receive() acepta ETH pero el contrato no tiene ninguna funcion de retiro/transferencia. Cualquier ETH enviado queda congelado para siempre. Vector: Bloqueo de fondos (frozen ether): perdida total de cualquier ETH depositado.	High	SWC-105	SC02:2026 Business Logic Errors
2	Crecimiento ilimitado de members y compute O(n^2) Root: Estructura no acotada y algoritmo cuadratico sin paginacion.	join() no deduplica ni limita; el mismo address puede inflar members[]. compute() recorre members en doble bucle anidado. Vector: Griefing/DoS: inflar members hasta que compute() (o futuros consumidores on-chain) exceda el gas del bloque.	Medium	SWC-128	SC02:2026 Business Logic Errors
3	join sin control ni unicidad Root: Validacion de membresia ausente.	Cualquiera se une multiples veces; no hay concepto de membresia unica ni baja. Vector: Distorsion del censo de la DAO.	Low	N/A	SC01:2026 Access Control

3. Analisis de logica de negocio

compute() no aporta valor de negocio (suma de indices) y no hay gobernanza real; los fondos recibidos son irrecuperables.

6. Benchmark metrics

3 Total	0 Critical	1 High	1 Medium	1 Low	0.88 Confidence	0.85 Precision	1.00 Coverage	40 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

HiddenTreasury

HiddenTreasury.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

60

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Bodega de depositos con balances por usuario y una tesoreria que el owner puede mover.
Actores	Owner (transferToTreasury/changeOwner), Usuarios (deposit/withdraw).
Flujo de fondos	ETH entra por deposit()/receive(); sale por withdraw() (usuario) o transferToTreasury() (owner, sin limite).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	El owner puede drenar fondos de los usuarios Root: No se segrega la tesoreria del owner de los depositos de usuarios; el privilegio admin alcanza fondos ajenos.	transferToTreasury() permite al owner enviar hasta address(this).balance a cualquier direccion, sin descontarlo de balances[]. Mueve ETH que pertenece contablemente a los usuarios. Vector: El owner transfiere todo el balance a su address; los usuarios quedan con balances[] >0 pero withdraw() revierte por falta de ETH (insolvencia).	High	SWC-105	SC02:2026 Business Logic Errors
2	changeOwner sin validar address(0) Root: Falta require(newOwner != address(0)).	changeOwner() acepta cualquier direccion, incluida address(0), lo que puede dejar el contrato sin owner valido. Vector: Perdida accidental/maliciosa de la administracion.	Low	SWC-105	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

withdraw() si respeta Checks-Effects-Interactions (resta antes del call). El riesgo real es la solvencia: el owner puede vaciar el contrato dejando impagables los balances de usuario.

6. Benchmark metrics

2	0	1	0	1	0.90	0.88	1.00	50	60
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Reserva de habitaciones de hotel: el owner registra hoteles y los clientes pagan por reservar segun tipo de habitacion y dias.
Actores	Owner (registerHotel), Clientes (bookHotel).
Flujo de fondos	El cliente paga ETH en bookHotel(); el ETH se queda en el contrato sin salida.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	La reserva pagada nunca se almacena Root: Variable local en memory que no se persiste en storage.	bookHotel() cobra el ETH y crea Booking memory b, pero nunca hace push a hotels[hotelName].bookings ni a customerBookings[]. La reserva se descarta al terminar la funcion. Vector: El cliente paga pero no queda constancia de la reserva; getCustomerBookings() siempre devuelve vacio.	High	N/A	SC02:2026 Business Logic Errors
2	Fondos de reservas bloqueados (sin retiro) Root: Falta funcion withdraw para el owner.	No existe funcion para que el owner (ni nadie) retire el ETH cobrado por las reservas. Queda congelado. Vector: Bloqueo permanente del ingreso de las reservas.	High	SWC-105	SC02:2026 Business Logic Errors
3	Sin reembolso ni cancelacion Root: Logica de liquidacion incompleta.	No hay mecanismo de cancelacion ni devolucion del exceso pagado (msg.value puede superar el precio). Vector: El cliente pierde el exceso enviado por encima del precio estimado.	Low	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

El flujo de negocio esta roto: se cobra un servicio que no se registra y cuyo dinero nadie puede recuperar; getCustomerBookings opera sobre un array siempre vacio.

6. Benchmark metrics

3 Total	0 Critical	2 High	0 Medium	1 Low	0.90 Confidence	0.88 Precision	0.95 Coverage	60 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

Lotery

Lotery.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

60

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Loteria: los jugadores compran tickets con ETH y se sortea un ganador.
Actores	Jugadores (buyTickets), quien llame drawWinner (cualquiera).
Flujo de fondos	ETH entra por buyTickets()/receive(); no hay pago de premio (sin salida de fondos).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Aleatoriedad controlada por el llamante Root: Ausencia de fuente de entropia segura (p.ej. VRF); la 'aleatoriedad' es un input externo.	drawWinner(uint256 randomness) usa un parametro suministrado por quien llama como unica fuente de azar; el resultado es totalmente predecible y elegible. Vector: El atacante calcula el randomness que selecciona su propia direccion como ganadora.	High	SWC-120	SC02:2026 Business Logic Errors
2	Sin pago de premio: fondos bloqueados Root: Falta logica de distribucion del premio.	drawWinner es view y solo devuelve una direccion; no transfiere el bote al ganador. No hay funcion que pague. El ETH queda congelado. Vector: Bloqueo permanente del bote acumulado.	High	SWC-105	SC02:2026 Business Logic Errors
3	Peso de tickets inconsistente Root: Modelo de probabilidad mal implementado.	buyTickets hace un unico players.push por llamada aunque se compren varios tickets; el peso real difiere del conteo en tickets[]. poolWeight usa el balance, mezclando unidades. Vector: Distribucion injusta de probabilidades respecto a los tickets pagados.	Medium	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

La loteria no es ni justa ni funcional: el ganador es manipulable y nunca cobra; los fondos quedan atrapados.

6. Benchmark metrics

3 Total	0 Critical	2 High	1 Medium	0 Low	0.90 Confidence	0.88 Precision	1.00 Coverage	50 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Mercado simple de NFTs: un vendedor lista un precio y un comprador paga para adquirir el id.
Actores	Vendedor (list), Comprador (buy).
Flujo de fondos	buy() reenvia msg.value directamente al seller global.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	seller y price globales sobrescribibles por cualquiera Root: Estado de listado global y compartido en lugar de por token; sin verificacion de propiedad.	list() fija variables globales seller y price sin verificar propiedad del NFT ni asociarlas a un id. Cualquiera puede sobrescribirlas en cualquier momento. Vector: Front-running: el atacante llama list() justo antes del buy() de la victima para convertirse en seller y cobrar el pago, o cambia price.	High	SWC-114	SC01:2026 Access Control
2	Compra sin custodia real del activo Root: Modelo de propiedad/escrow ausente.	No hay NFT en custodia; buy() solo escribe ownerOf[id]=msg.sender y paga al seller. No valida que el id exista o pertenezca al seller. El parametro id de list() ni se usa. Vector: Pago por un activo inexistente; intercambio no atomico.	Medium	N/A	SC02:2026 Business Logic Errors
3	Falta validacion de precio Root: Sin require(price>0).	price puede ser 0; require(msg.value >= price) sin mensaje y sin minimo. Vector: Compras a precio 0 o estados degenerados.	Low	N/A	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

El listado compartido permite secuestrar la venta; comprador y vendedor no tienen garantias atomicas de intercambio.
--

6. Benchmark metrics

3 Total	0 Critical	1 High	1 Medium	1 Low	0.88 Confidence	0.85 Precision	1.00 Coverage	45 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Acunacion (mint) de NFTs con precio, suministro maximo y retiro de ingresos por el owner.
Actores	Owner (changePrice/withdraw), Usuarios (mint).
Flujo de fondos	ETH entra por mint()/receive(); sale por withdraw() (owner).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	No se acuna ningun token real Root: Logica de acunacion (almacenamiento de propiedad) ausente.	mint() solo incrementa contadores y emite eventos; no implementa ERC-721 ni asigna propiedad de un tokenId. El usuario paga sin recibir un activo transferible. Vector: El comprador paga por un NFT que no existe on-chain.	Medium	N/A	SC02:2026 Business Logic Errors
2	Limite por wallet declarado pero no aplicado Root: Variable de control sin enforcement.	minted[msg.sender] se incrementa pero nunca se usa para limitar; no hay tope por direccion. Vector: Una sola wallet puede acaparar todo el suministro.	Low	N/A	SC02:2026 Business Logic Errors
3	Sin reembolso del exceso pagado Root: Falta logica de reembolso/validacion exacta.	Acepta msg.value >= mintPrice y retiene el exceso; no devuelve la diferencia. Vector: Perdida del sobrepago del usuario.	Low	N/A	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

Control de acceso de admin correcto y patron CEI razonable; los problemas son de logica de negocio (no entrega NFT, no aplica limite, no reembolsa). Riesgo de drenaje bajo.
--

6. Benchmark metrics

3 Total	0 Critical	0 High	1 Medium	2 Low	0.85 Confidence	0.82 Precision	1.00 Coverage	45 Time (s)	10 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Boveda de depositos que pretende custodiar ETH por usuario.
Actores	Usuarios (deposit), cualquiera (adminWithdraw).
Flujo de fondos	ETH entra por deposit()/receive(); adminWithdraw() envia TODO el balance a quien llame.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	adminWithdraw sin control de acceso: drenaje total Root: Funcion administrativa critica sin modificador onlyOwner.	adminWithdraw() no comprueba propietario ni rol; envia address(this).balance a msg.sender. Pese al nombre 'admin', cualquiera puede llamarla. Vector: Un atacante llama adminWithdraw() y vacia todos los depositos del contrato.	Critical	SWC-105	SC01:2026 Access Control
2	Contabilidad de deposits inutil Root: Logica de retiro desligada del registro de saldos.	deposits[] se registra pero nunca limita el retiro; no hay relacion entre lo depositado y lo retirable. Vector: Cualquiera retira fondos ajenos sin respetar su saldo.	Medium	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

El nombre 'SafeVault' es enganoso: el contrato es trivialmente vaciable por cualquier direccion.
--

6. Benchmark metrics

2	1	0	1	0	0.95	0.95	1.00	35	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

SecureVoteMultiSig

SecureVoteMultiSig.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Multisig: varios owners aprueban un txHash y, alcanzado el umbral required, se ejecuta una transferencia.
Actores	Owners (approve), cualquiera (execute).
Flujo de fondos	execute() envia value ETH a to si hay suficientes aprobaciones de owners para txHash.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	txHash no vinculado a (to, value) Root: Desacople entre la autorizacion (hash) y los parametros reales de la accion.	execute(to, value, txHash) no comprueba que txHash == hash(to,value,...). Los owners aprueban un hash abstracto pero execute admite cualquier destino e importe mientras ese hash tenga aprobaciones. Vector: Con un txHash que ya reune 'required' aprobaciones, el atacante ejecuta una transferencia a su address por el importe que quiera.	Critical	SWC-121	SC02:2026 Business Logic Errors
2	Sin marca de ejecutado: replay Root: Falta proteccion anti-replay/nonce por transaccion.	No existe un flag executed[txHash]; execute() puede llamarse repetidamente con el mismo txHash aprobado. Vector: Replay: vaciar el contrato repitiendo execute() hasta agotar el balance.	Critical	SWC-121	SC02:2026 Business Logic Errors
3	required y owners sin validacion Root: Constructor sin invariantes de configuracion.	No se valida required>0, required<=owners.length ni unicidad de owners; required=0 permite ejecutar sin aprobaciones. Vector: Configuracion degenerada que anula el umbral del multisig.	Medium	SWC-123	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

Pese al nombre 'Secure', el multisig no ata la aprobacion al contenido de la transaccion ni evita la repeticion, por lo que no ofrece seguridad real.

6. Benchmark metrics

3	2	0	1	0	0.90	0.88	1.00	65	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Subasta inglesa: las pujas suben el highestBid y al cerrar el vendedor cobra la puja mas alta.
Actores	Seller (endAuction), Pujadores (bid).
Flujo de fondos	Cada puja envia ETH al contrato; endAuction() paga highestBid al seller.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Las pujas perdedoras nunca se devuelven Root: Falta patron pull-payment para reembolsar a los pujadores superados.	Al ser superado, el anterior highestBidder no recupera su ETH; no existe pendingReturns ni funcion de retiro para perdedores. Solo se paga highestBid al seller. Vector: La suma de todas las pujas superadas queda atrapada permanentemente en el contrato.	High	SWC-104	SC02:2026 Business Logic Errors
2	Sin plazo: el seller cierra cuando quiere Root: Ausencia de control temporal de la subasta.	No hay deadline; endAuction() depende solo de la voluntad del seller, que puede cerrar en el momento mas favorable o no cerrar nunca (griefing). Vector: El seller manipula el cierre o congela la subasta.	Medium	N/A	SC02:2026 Business Logic Errors
3	El ganador no recibe ningun activo Root: Liquidacion del activo no implementada.	No se transfiere bien/NFT alguno al highestBidder al finalizar; la subasta no liquida el objeto subastado. Vector: El ganador paga y no recibe contraprestacion.	Low	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

El patron push de un unico pago al seller deja sin reembolso a los perdedores; el cierre discrecional habilita griefing.
--

6. Benchmark metrics

3 Total	0 Critical	1 High	1 Medium	1 Low	0.90 Confidence	0.88 Precision	1.00 Coverage	50 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

TokenOracleDEX

TokenOracleDEX.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	DEX simple: compra/venta de un token interno contra ETH usando un precio almacenado.
Actores	Cualquiera (setPrice/buy/sell). Sin admin real.
Flujo de fondos	buy() acumula balance segun price; sell() paga ETH segun price.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	setPrice sin control: manipulacion de precio Root: Oraculo de precio interno controlable por cualquier actor; sin control de acceso ni fuente fiable.	setPrice(p) es publica y sin restricciones; cualquiera fija el precio a voluntad antes de comprar o vender. Vector: Comprar con price bajo, subir price con setPrice y vender, extrayendo mas ETH del depositado hasta drenar el contrato.	Critical	SWC-105	SC03:2026 Price Oracle Manipulation
2	Reentrancy en sell() Root: Violacion de Checks-Effects-Interactions (interaccion antes del efecto).	sell() ejecuta el call de ETH ANTES de restar balances[msg.sender]. Un contrato malicioso reentra antes de la actualizacion del saldo. Vector: Reentrada recursiva en sell() para retirar repetidamente con el mismo saldo.	Critical	SWC-107	SC08:2026 Reentrancy
3	Division por cero y unidades inconsistentes Root: Modelo aritmetico/AMM inexistente; sin invariantes de liquidez.	sell() calcula amount/price; si price=0 revierte. buy multiplica y sell divide con unidades incoherentes respecto al ETH real, generando insolvencia. Vector: DoS por price=0 y descuadre contable entre balances y ETH disponible.	Medium	SWC-101	SC07:2026 Arithmetic Errors

3. Analisis de logica de negocio

Economicamente roto y drenable: el precio es manipulable por cualquiera y sell() es reentrante; la contabilidad no guarda relacion con el ETH custodiado.

6. Benchmark metrics

3	2	0	1	0	0.93	0.90	1.00	60	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Banco/boveda: los usuarios depositan ETH y retiran segun su saldo.
Actores	Usuarios (deposit/withdraw), Owner (declarado, sin uso).
Flujo de fondos	ETH entra por deposit()/receive(); sale por withdraw().

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Reentrancy clasica en withdraw() Root: Orden incorrecto: interaccion antes del efecto (no se respeta Checks-Effects-Interactions).	withdraw() hace el call de ETH ANTES de restar balances[msg.sender]. El receptor malicioso reentra en withdraw() con el saldo aun intacto. Vector: Contrato atacante con fallback que reentra withdraw() y drena todo el ETH del banco (patron tipo The DAO).	Critical	SWC-107	SC08:2026 Reentrancy
2	Variable owner sin uso Root: Variable declarada y no implementada.	owner se asigna en el constructor pero no se utiliza en ninguna funcion. Vector: N/A (codigo muerto que puede inducir falsa sensacion de control).	Low	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

Aparte de la reentrancy, la logica de saldos es correcta; el unico actor de riesgo es un retirante malicioso reentrante.
--

6. Benchmark metrics

2	1	0	0	1	0.95	0.95	1.00	40	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).

1. Identificacion del contrato

Proposito	Staking con recompensas: los usuarios depositan ETH, acumulan recompensa y retiran.
Actores	Usuarios (deposit/reward/withdraw).
Flujo de fondos	ETH entra por deposit(); withdraw() paga segun stake[]; reward() sube stake[] sin aportar ETH.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	reward() infla el saldo sin depositar ETH Root: Acreditacion de saldo sin respaldo de fondos ni control de acceso; recompensa autoasignable.	reward(uint256 r) es publica y permite a cualquiera incrementar su propio stake[msg.sender] en una cantidad arbitraria sin enviar ETH. Vector: El atacante llama reward(grande) y luego withdraw(grande), cobrando ETH real de los depositos de otros usuarios hasta vaciar el contrato.	Critical	SWC-105	SC02:2026 Business Logic Errors
2	Insolvencia estructural Root: No hay fuente real de rendimiento ni invariante de solvencia.	La suma de stake[] puede superar enormemente el ETH custodiado por culpa de reward(); el contrato promete mas de lo que tiene. Vector: Corrida: los primeros en retirar cobran; el resto queda sin fondos.	High	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

withdraw() respeta CEI (resta antes del call), pero reward() rompe por completo la solvencia: cualquiera acuna saldo gratis y lo convierte en ETH ajeno.
--

6. Benchmark metrics

2	1	1	0	0	0.93	0.92	1.00	45	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).